

**PENERAPAN APACHE APISIX, FORTRESS, SKYWALKING,
DAN HERTZBEAT UNTUK PENGAMANAN API SERTA VISIBILITAS
LAYANAN PADA SISTEM INFORMASI MANAJEMEN FASILITAS
(UPNFIK)**

Mata Kuliah : Keamanan Jaringan



Kelompok 7:

Fadilla Putra Karnansyah	2410512009
Muhammad Akbar Al Islami	2410512012
Rafi Fauzi Alfariz	2410512015
Torikh Abdullah Naser	2410512032

**PROGRAM STUDI S1 SISTEM INFORMASI
FAKULTAS ILMU KOMPUTER
UNIVERSITAS PEMBANGUNAN NASIONAL "VETERAN" JAKARTA
2026/2027**

DAFTAR ISI

DAFTAR ISI.....	2
BAB 1.....	5
PENDAHULUAN.....	5
1.1 Latar Belakang.....	5
1.2 Rumusan Masalah.....	5
1.3 Tujuan.....	5
1.4 Batasan Masalah.....	6
BAB 2.....	7
TINJAUAN PUSTAKA.....	7
2.1 OSI Layer 5-6-7.....	7
2.1.1 Session Layer.....	7
2.1.2 Presentation Layer.....	7
2.1.3 Application Layer.....	7
2.2 Ancaman Keamanan pada Layer 5–6–7.....	8
2.2.1 Brute-Force Login (Layer 5 & 7).....	8
2.2.2 Broken Access Control / BOLA (Layer 7).....	8
2.2.3 Data Leakage via HTTP Headers (Layer 6).....	8
2.2.4 Request Flooding / DoS (Layer 7).....	8
2.2.5 Insecure TLS Configuration (Layer 6).....	9
2.2.6 Phishing & Credentials Leak (Layer 5 & 7).....	9
2.3 Teknologi Apache Software Foundation.....	9
2.3.1 Apache APISIX.....	9
2.3.2 Apache SkyWalking.....	10
2.3.3 Apache HertzBeat.....	10
2.3.4 Apache Fortress.....	10
BAB 3.....	11
ANALISIS DAN PERANCANGAN.....	11
3.1 Deskripsi Studi Kasus.....	11
3.2 Identifikasi Aset.....	11
3.3 Identifikasi Ancaman.....	12
3.4 Pemetaan Kontrol Keamanan.....	13
3.5 Diagram Arsitektur.....	14
BAB 4.....	16
IMPLEMENTASI SIMULASI.....	16
4.1 Lingkungan Implementasi.....	16
4.2 Konfigurasi Teknologi.....	16
4.2.1 Konfigurasi Apache APISIX.....	17
4.2.2 Konfigurasi Apache SkyWalking.....	18
4.2.3 Konfigurasi Apache HertzBeat.....	18
4.2.4 Konfigurasi Apache Fortress.....	19

4.3 Implementasi Kontrol Keamanan.....	19
BAB 5.....	23
PENGUJIAN DAN EVALUASI.....	23
5.1 Skenario Pengujian.....	23
5.2 Hasil Pengujian.....	24
5.3 Hasil Analisis.....	27
BAB 6	
KESIMPULAN DAN REKOMENDASI.....	29
6.1 Kesimpulan.....	29
6.2 Rekomendasi.....	29

Abstrak

Sistem Informasi Manajemen Fasilitas (UPNFIK) rentan terhadap ancaman pada layer 5, 6, dan 7 model OSI. Celah keamanan utama meliputi serangan *brute-force* (Denial of Service), kebocoran identitas server melalui *header* HTTP, transmisi data tanpa enkripsi, serta *Broken Access Control* (BAC) yang memungkinkan akses ilegal ke data sensitif. Untuk memitigasi risiko tersebut, penelitian ini merancang arsitektur pertahanan menggunakan ekosistem Apache Software Foundation. Apache APISIX diterapkan sebagai API Gateway untuk mengelola enkripsi TLS dan pembatasan laju trafik (*rate limiting*). Apache Fortress diintegrasikan untuk memusatkan kebijakan otorisasi melalui *Role-Based Access Control* (RBAC). Selain itu, Apache SkyWalking dan Apache HertzBeat digunakan untuk *distributed tracing* serta pemantauan ketersediaan layanan (*availability monitoring*). Metode pengujian dilakukan melalui simulasi serangan otomatis dan manual secara lokal di dalam lingkungan isolasi Docker. Skenario evaluasi mencakup penetrasi pada *endpoint* autentikasi, uji batas otorisasi pengguna biasa, dan analisis respons sistem. Hasil utama membuktikan arsitektur ini mampu menolak *spam request* secara otomatis dengan mengembalikan status HTTP 429, menggagalkan pembajakan akses data rahasia dengan status HTTP 403, serta menutupi identitas asli *backend*. Secara bersamaan, anomali jaringan terekam secara utuh pada dasbor observabilitas. Kesimpulannya, penerapan tumpukan teknologi Apache terbukti efektif dalam menutup celah keamanan *Session*, *Presentation*, dan *Application Layer*, sehingga kerahasiaan, integritas, dan ketersediaan layanan UPNFIK dapat terjamin.

Kata Kunci: Keamanan Jaringan, Layer OSI, *API Gateway*, *Role-Based Access Control*, Apache Foundation.

BAB 1

PENDAHULUAN

1.1 Latar Belakang

Sebagai respons terhadap kebutuhan digitalisasi kampus di UPN "Veteran" Jakarta, dirancanglah sebuah purwarupa (*prototype*) Sistem Informasi Manajemen Fasilitas (UPNFIX) untuk mengelola data pelaporan kerusakan infrastruktur. Meskipun masih berupa simulasi pengembangan, sistem ini dirancang untuk berinteraksi langsung dengan *database* MySQL melalui *endpoint* API Next.js dan ditujukan untuk diakses secara terbuka oleh berbagai elemen kampus. Karakteristik arsitektur terbuka seperti ini memiliki eksposur risiko keamanan siber yang tinggi pada tiga lapisan teratas model OSI. Tanpa rancangan proteksi yang memadai, sistem rentan terhadap serangan pembajakan akun (*session hijacking*) pada Layer 5 (Session), penyadapan transmisi data *cleartext* dan kebocoran identitas *server* pada Layer 6 (Presentation), serta ancaman *brute-force*, *Request Flooding* (DoS), dan *Broken Access Control* pada Layer 7 (Application). Jika celah ini dieksploitasi ketika sistem diimplementasikan, dampaknya dapat melumpuhkan layanan dan mengacaukan integritas pelaporan kerusakan fasilitas. Oleh karena itu, simulasi mitigasi keamanan berlapis di tingkat tepi jaringan (*edge*) menggunakan *API Gateway* dan platform observabilitas dari ekosistem Apache Software Foundation sangat mendesak untuk diuji, guna menjamin kerahasiaan, integritas, dan ketersediaan layanan UPNFIX.

1.2 Rumusan Masalah

1. Bagaimana mengidentifikasi dan memitigasi ancaman keamanan siber pada Layer 5, 6, dan 7 OSI pada purwarupa (*prototype*) Sistem Informasi UPNFIX?
2. Bagaimana mengintegrasikan Apache APISIX, Apache Fortress, Apache SkyWalking, dan Apache HertzBeat ke dalam sebuah lingkungan kontainer Docker yang terisolasi?
3. Bagaimana mengukur efektivitas kontrol akses, perlindungan *gateway*, serta visibilitas pemantauan layanan setelah arsitektur keamanan diimplementasikan?

1.3 Tujuan

1. Mengidentifikasi potensi ancaman keamanan pada Layer 5, 6, dan 7 OSI pada purwarupa (*prototype*) Sistem Informasi UPNFIX.

2. Merancang arsitektur keamanan berlapis menggunakan teknologi *open-source* Apache Foundation.
3. Mengimplementasikan simulasi pengamanan yang mencakup perlindungan *API Gateway*, kontrol otorisasi terpusat (RBAC), serta pemantauan visibilitas layanan (*tracing* dan *monitoring*) di dalam lingkungan kontainer terisolasi.
4. Mengevaluasi efektivitas kontrol keamanan dengan membandingkan respons sistem sebelum dan sesudah arsitektur keamanan diimplementasikan.

1.4 Batasan Masalah

1. Fokus perancangan dan evaluasi keamanan hanya dibatasi pada tiga lapisan teratas model OSI, yaitu Layer 5 (*Session*), Layer 6 (*Presentation*), dan Layer 7 (*Application*).
2. Implementasi dan pengujian sistem murni dilakukan secara lokal menggunakan *container* Docker pada sistem operasi Windows, tanpa menggunakan lingkungan *Virtual Machine* (VM).
3. Pengujian kerentanan dan simulasi serangan (seperti *brute-force* dan eksploitasi otorisasi) dilakukan secara terbatas dan etis murni pada lingkungan purwarupa (*prototype*) lokal, bukan pada peladen (*server*) asli milik UPN "Veteran" Jakarta.
4. Seluruh data yang digunakan di dalam *database* MySQL, termasuk data pelaporan, pengguna, dan kredensial, bersifat data buatan (*dummy*) yang di-*generate* khusus untuk keperluan simulasi.
5. Ruang lingkup teknologi mitigasi keamanan dan observabilitas difokuskan secara eksklusif pada ekosistem Apache Software Foundation, yaitu Apache APISIX, Apache SkyWalking, Apache HertzBeat dan Apache Fortress

BAB 2

TINJAUAN PUSTAKA

2.1 OSI Layer 5-6-7

Model *Open Systems Interconnection* (OSI) merupakan kerangka konseptual standar yang mendefinisikan fungsi komunikasi jaringan komputer ke dalam tujuh lapisan. Dalam konteks arsitektur keamanan *web* modern, tiga lapisan teratas berperan sangat kritikal karena berhadapan langsung dengan logika aplikasi dan interaksi data pengguna

2.1.1 Session Layer

Lapisan ini bertanggung jawab penuh untuk membangun, memelihara, sinkronisasi, hingga menghentikan sesi komunikasi antar entitas aplikasi. Dalam ekosistem aplikasi berbasis *web*, fungsi *Session Layer* erat kaitannya dengan mekanisme autentikasi dan manajemen sesi pengguna. Perlindungan pada layer ini mencakup pengelolaan siklus hidup token autentikasi (*JSON Web Tokens*/JWT) dan *cookie-based session*, untuk memastikan bahwa sesi tidak disalahgunakan oleh pihak ketiga melalui teknik pembajakan sesi (*session hijacking*).

2.1.2 Presentation Layer

Lapisan ini bertindak sebagai penerjemah (translator) jaringan yang mengatur format, representasi, dan sintaksis pertukaran data antar sistem. Fokus utama keamanan pada *Presentation Layer* adalah proses enkripsi dan dekripsi data, seperti penerapan protokol TLS (*Transport Layer Security*) atau HTTPS untuk mencegah penyadapan. Selain itu, lapisan ini juga berfungsi melakukan sanitasi *payload* data dan penyembunyian *header* HTTP (*masking*) agar infrastruktur tidak membocorkan identitas peladen (*server*) ke pihak luar yang dapat memicu celah eksploitasi (*data leakage*).

2.1.3 Application Layer

Lapisan ketujuh merupakan titik interaksi langsung antara pengguna dengan layanan jaringan atau aplikasi. Pada lapisan ini, kapabilitas keamanan jaringan modern diterapkan dalam bentuk perlindungan antarmuka pemrograman aplikasi (*API Security*). Kontrol keamanan yang berjalan di layer ini sangat kompleks, mencakup otorisasi berlapis seperti *Role-Based Access Control* (RBAC), pembatasan frekuensi

akses (*rate limiting*) untuk mencegah serangan *brute-force* atau DoS, serta analisis aktivitas (*tracing*) untuk mendeteksi anomali trafik secara aktual.

2.2 Ancaman Keamanan pada Layer 5–6–7

2.2.1 Brute-Force Login (Layer 5 & 7)

Serangan *brute-force* merupakan metode peretasan di mana penyerang menggunakan skrip otomatis untuk menebak kredensial (kombinasi *username* dan *password*) secara berulang-ulang dengan frekuensi tinggi. Pada Layer 5 dan 7, serangan ini mengeksploitasi mekanisme autentikasi dan manajemen sesi. Tanpa adanya kontrol pembatasan laju (*rate limiting*), penyerang dapat terus mencoba kombinasi kredensial hingga berhasil mengambil alih akun pengguna (*Account Takeover*).

2.2.2 Broken Access Control / BOLA (Layer 7)

Broken Access Control (BAC) atau *Broken Object Level Authorization* (BOLA) adalah kerentanan kritis pada Layer 7 di mana aplikasi gagal membatasi hak otorisasi pengguna secara ketat. Celah ini memungkinkan pengguna dengan hak akses rendah (seperti pengguna biasa) untuk memanipulasi parameter antarmuka pemrograman aplikasi (API) guna mengakses, memodifikasi, atau menghapus data administratif dan sumber daya milik pengguna lain secara ilegal.

2.2.3 Data Leakage via HTTP Headers (Layer 6)

Kebocoran data (*Data Leakage*) melalui *header* HTTP terjadi pada *Presentation Layer* ketika peladen (*server*) secara tidak sengaja mengembalikan informasi sensitif mengenai infrastruktur yang digunakan (misalnya versi peladen *web* atau *framework backend*) melalui respons bawaan peladen. Informasi ini dapat dimanfaatkan oleh penyerang untuk melakukan tahap pengintaian (*reconnaissance*) guna memetakan jenis kerentanan (*Common Vulnerabilities and Exposures* / CVE) yang relevan dengan teknologi tersebut.

2.2.4 Request Flooding / DoS (Layer 7)

Denial of Service (DoS) berbasis *Request Flooding* pada *Application Layer* adalah jenis serangan asimetris di mana penyerang membanjiri peladen dengan jutaan permintaan HTTP/HTTPS tiruan. Serangan ini bertujuan untuk menguras sumber

daya komputasi peladen (CPU dan memori), yang pada akhirnya menyebabkan penurunan kinerja secara drastis (*resource exhaustion*) atau bahkan kelumpuhan total layanan (*downtime*) bagi pengguna yang sah.

2.2.5 Insecure TLS Configuration (Layer 6)

Kegagalan dalam mengonfigurasi *Transport Layer Security* (TLS) yang memadai pada *Presentation Layer* menyebabkan data ditransmisikan dalam format teks terang (*cleartext*). Transmisi yang tidak dienkripsi ini membuka celah keamanan yang sangat fatal, di mana peretas yang berada di dalam jaringan yang sama dapat melakukan intersepsi dan penyadapan (*Man-in-the-Middle Attack*) terhadap paket data sensitif, seperti token otorisasi dan kata sandi pengguna.

2.2.6 Phishing & Credentials Leak (Layer 5 & 7)

Pencurian data kredensial atau pembajakan sesi (*session hijacking*) umumnya mengeksploitasi kelemahan pada Layer 5. Insiden ini sering diawali oleh teknik rekayasa sosial (*social engineering*) seperti *phishing*, di mana pengguna membagikan sesi login atau kredensial pada antarmuka palsu. Selain itu, manajemen token yang buruk seperti token otorisasi yang tidak memiliki batas waktu kedaluwarsa yang aman (*expired time*) dapat dieksploitasi oleh pihak ketiga untuk mempertahankan akses tidak sah ke dalam sistem secara permanen.

2.3 Teknologi Apache Software Foundation

2.3.1 Apache APISIX

Apache APISIX berfungsi sebagai *API Gateway* tingkat tinggi yang bersifat *cloud-native* untuk merutekan dan memfilter seluruh trafik jaringan HTTP/HTTPS. Teknologi ini mendukung penuh perlindungan pada Layer 6 (*Presentation*) dan Layer 7 (*Application*). Dalam arsitektur sistem, APISIX berposisi di tepi jaringan (*edge*) sebagai garda terdepan (*reverse proxy*) yang memisahkan klien publik dengan layanan *backend* privat. Relevansinya dengan keamanan jaringan sangat krusial; APISIX bertindak sebagai perisai pertama melalui fitur enkripsi *TLS Termination*, penyembunyian identitas peladen (*header masking*), serta pembatasan trafik (*rate limiting*) untuk menahan serangan *brute-force*.

2.3.2 Apache SkyWalking

Apache SkyWalking berfungsi sebagai platform *Application Performance Management* (APM) untuk melakukan pelacakan terdistribusi (*distributed tracing*) dan agregasi log operasional. Platform ini menganalisis aktivitas trafik pada Layer 7 (*Application*) dan berposisi sebagai peladen observabilitas *backend* (*OAP Server*) yang mengumpulkan data *trace* secara asinkron tanpa dilalui trafik klien secara langsung. Dalam aspek keamanan, SkyWalking sangat relevan untuk memberikan transparansi penuh bagi administrator dalam mendeteksi anomali trafik, melacak sumber serangan *Request Flooding* (DoS), dan memfasilitasi investigasi audit.

2.3.3 Apache HertzBeat

Apache HertzBeat berfungsi sebagai sistem pemantauan ketersediaan (*availability monitoring*) dan peringatan dini (*alerting*) untuk mengawasi status waktu hidup (*uptime*) layanan. Berfokus pemantauan pada Layer 7 (*Application*), HertzBeat diposisikan sebagai pengawas eksternal (*active prober*) yang secara berkala memverifikasi respons dari layanan *gateway* maupun aplikasi. Relevansinya dengan keamanan jaringan adalah sebagai alarm pendeteksi utama; apabila terjadi kelumpuhan peladen akibat serangan *Denial of Service* (DoS), sistem ini akan memicu notifikasi instan agar administrator dapat melakukan mitigasi segera.

2.3.4 Apache Fortress

Apache Fortress berfungsi sebagai sistem manajemen kontrol akses terpusat berbasis peran (*Role-Based Access Control* / RBAC) yang mengelola delegasi hak akses pengguna secara dinamis. Beroperasi secara eksklusif pada **Layer 7 (*Application*)**, Fortress diposisikan di dalam jaringan internal yang terisolasi sebagai layanan identitas mandiri (*IAM server*). Relevansi keamanan dari teknologi ini terletak pada kemampuannya memisahkan aturan otorisasi dari kode aplikasi utama, sehingga secara absolut menutup celah *Broken Access Control* (BOLA) yang memungkinkan pengguna biasa memanipulasi parameter akses administratif.

BAB 3

ANALISIS DAN PERANCANGAN

3.1 Deskripsi Studi Kasus

Sistem Informasi Manajemen Fasilitas (UPNFIX) merupakan purwarupa aplikasi web berbasis Next.js dan basis data MySQL yang dirancang untuk mengelola tiket pelaporan kerusakan sarana prasarana kampus. Fitur intinya mencakup pelacakan status laporan (dari PENDING, DIPROSES, hingga SELESAI), rekam waktu penyelesaian, dan penambahan catatan admin. Sistem ini dioperasikan oleh dua aktor utama, yaitu USER (pelapor) dan ADMIN (pengelola), serta mencakup rancangan peran teoretis TEKNISI untuk mendemonstrasikan kapabilitas Role-Based Access Control (RBAC). Dalam operasionalnya, UPNFIX memproses data spesifik berupa rincian laporan (judul, kategori, lokasi, deskripsi) dan mewajibkan pengguna untuk mengunggah foto bukti kerusakan yang disimpan menggunakan cloud storage Cloudinary. Mengingat arsitektur bawaan sistem ini mengekspos endpoint API pelaporan dan autentikasi secara langsung ke publik tanpa mitigasi edge, UPNFIX sangat rentan terhadap eksploitasi identitas sesi, manipulasi hak akses otorisasi, kebocoran kunci API eksternal, hingga kelumpuhan layanan akibat serangan flooding request.

3.2 Identifikasi Aset

Berikut adalah tabel identifikasi aset kritis pada sistem informasi UPNFIX:

No	Nama Aset	Jenis Aset	Nilai Keamanan (Security Value)
1	MySQL Database (upnfix-db)	Data Sensitif	Menyimpan data kredensial terenkripsi pengguna, riwayat pelaporan kerusakan fasilitas, detail lokasi spesifik, dan tanggapan admin.
2	JWT Auth Cookie (token)	Kredensial Sesi	Cookie sesi pengguna/admin yang tersimpan di browser untuk memvalidasi hak akses ke dalam sistem.

3	API Endpoints	Layanan Aplikasi	Antarmuka API (/api/auth/login, /api/users, /api/reports) yang menerima dan menyajikan data sensitif.
4	Infrastruktur Server & Gateway	Infrastruktur Jaringan	Runtime server Next.js (upnfix-app), API Gateway (APISIX), serta platform monitoring (SkyWalking & HertzBeat).

3.3 Identifikasi Ancaman

Ancaman keamanan pada sistem UPNFIX dipetakan berdasarkan Layer OSI sebagai berikut:

No	Nama Aset	Jenis Aset	Nilai Keamanan (Security Value)
1	Brute-Force Login	Layer 5 & 7	JWT Auth Cookie, API Endpoints
2	Broken Access Control (BAC / BOLA)	Layer 7	MySQL Database, API Endpoints
3	Data Leakage via HTTP Headers	Layer 6	Infrastruktur Server & Gateway
4	Request Flooding / DoS	Layer 7	API Endpoints, Infrastruktur Server
5	Insecure TLS Configuration	Layer 6	MySQL Database, JWT Auth Cookie
6	Phishing & Credentials Leak	Layer 5 & 7	JWT Auth Cookie

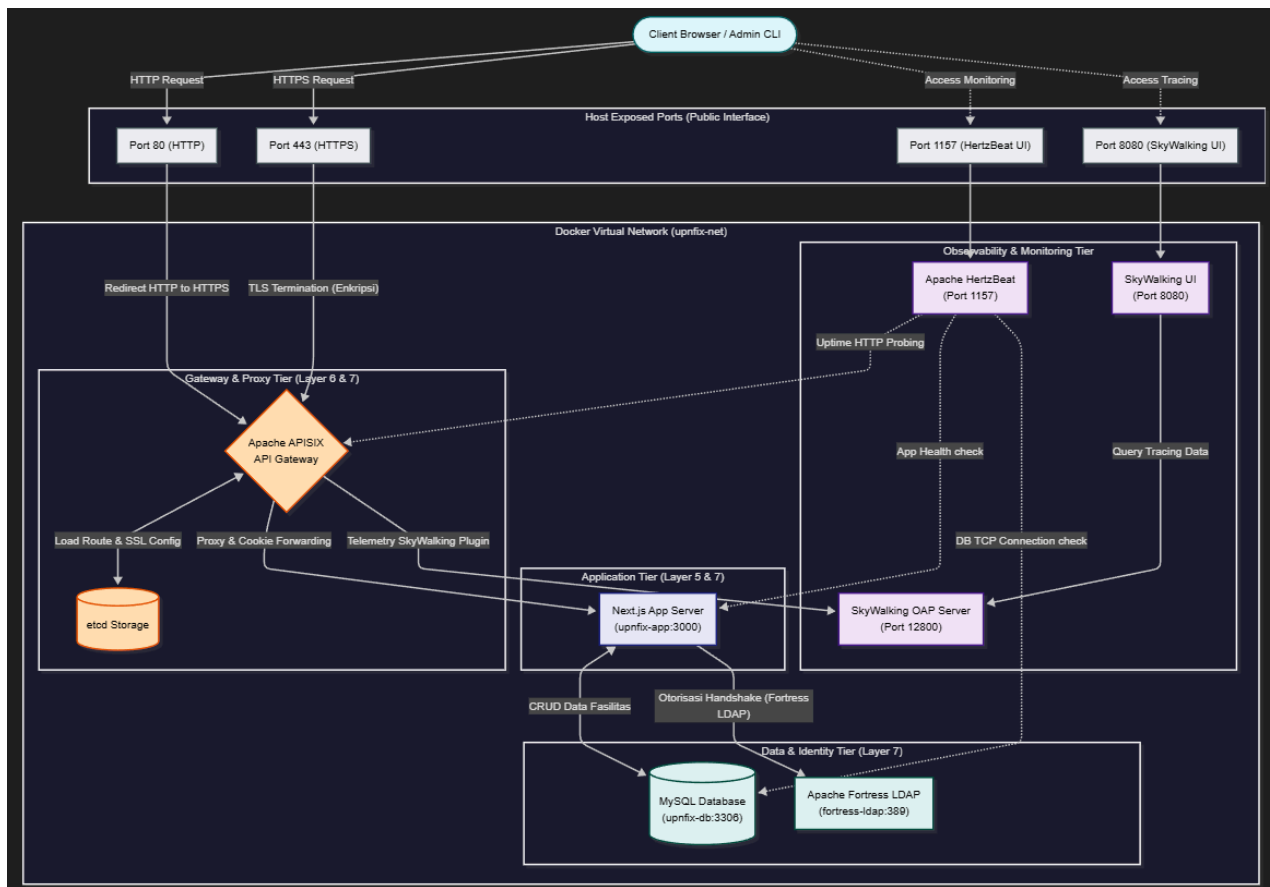
3.4 Pemetaan Kontrol Keamanan

Untuk memitigasi keenam ancaman di atas secara komprehensif, diterapkan pemetaan kontrol keamanan terintegrasi menggunakan Apache Stack dan penguatan Next.js:

1. Mitigasi Brute-Force Login (T1):
 - Mengonfigurasi plugin limit-count pada Apache APISIX Gateway untuk membatasi akses pada rute /api/auth/login dan /api/auth/signup maksimal 10 request/menit per IP. Request berlebih otomatis ditolak dengan kode 429 Too Many Requests.
2. Mitigasi Broken Access Control (T2):
 - Mengimplementasikan validasi otentikasi ketat pada Next.js middleware.js (Layer 5) untuk mencegah akses tidak sah ke rute sensitif.
 - Merancang integrasi otorisasi terdesentralisasi berbasis LDAP Directory Service menggunakan Apache Fortress (Layer 7) untuk mengelola peran (ADMIN, USER, TEKNIISI) secara dinamis.
3. Mitigasi Data Leakage via HTTP Headers (T3):
 - Mengonfigurasi plugin response-rewrite pada Apache APISIX untuk menghapus header runtime X-Powered-By dan menyamarkan signature server asli menjadi Server: UPNFIX-Gateway.
 - Menyuntikkan security headers tambahan seperti X-Frame-Options: DENY dan X-Content-Type-Options: nosniff pada setiap respon HTTP gateway.
4. Mitigasi Request Flooding / DoS (T4):
 - Menerapkan batas koneksi global pada level APISIX Gateway.
 - Apache HertzBeat diintegrasikan untuk memantau kesehatan kontainer aktif secara real-time dan mengirim alarm jika ada anomali uptime.
 - Apache SkyWalking memvisualisasikan data distributed tracing trafik HTTP guna mempermudah audit investigasi latensi tidak wajar.
5. Mitigasi Insecure TLS Configuration (T5):
 - Menerapkan enkripsi data pada Presentation Layer dengan melakukan TLS Termination pada port 443 di Apache APISIX Gateway.
 - Seluruh request HTTP biasa (Port 80) otomatis dialihkan (HTTP-to-HTTPS redirect) menggunakan status HTTP 301 ke HTTPS (Port 443) yang terenkripsi.
6. Mitigasi Phishing & Credentials Leak (T6):

- Hardening token sesi JWT dengan menyetel masa kedaluwarsa yang singkat (1 jam).
- Token disimpan di dalam browser menggunakan Secure Cookie dengan flag HttpOnly (mencegah pencurian token lewat script/XSS), Secure (hanya dikirim via HTTPS), dan SameSite=Lax.
- Menyediakan rute khusus /api/auth/logout yang berfungsi membersihkan cookie sesi dari browser secara permanen saat pengguna keluar.

3.5 Diagram Arsitektur



Gambar 1 Diagram Arsitektur

Penjelasan Komponen Arsitektur:

1. Host Exposed Ports (Interface Publik):

- Pintu masuk utama lalu lintas data bagi pengguna. Lalu lintas HTTP (Port 80) dialihkan ke HTTPS (Port 443) demi keamanan data.
- Port 1157 dan 8080 diekspos ke host agar Administrator sistem dapat memantau status monitoring (HertzBeat) dan grafik distributed tracing (SkyWalking).

2. Gateway Tier (Apache APISIX):
 - Berfungsi sebagai reverse proxy di tepi jaringan (edge). APISIX melakukan enkripsi/dekripsi HTTPS (TLS Termination) dan menerapkan pembatasan laju (Rate Limiting) sebelum request menyentuh Next.js.
3. Application Tier (Next.js):
 - Menjalankan logika bisnis aplikasi dan memvalidasi cookie sesi JWT (Layer 5 Session).
4. Data & Identity Tier:
 - MySQL menyimpan data relasional dummy secara aman.
 - Apache Fortress LDAP memusatkan hak akses (decoupled authorization).
5. Observability & Monitoring Tier:
 - HertzBeat secara berkala mengirimkan probe sintetik untuk memastikan ketersediaan server.
 - SkyWalking menerima data trace dari APISIX telemetry plugin guna mendeteksi anomali jaringan.

BAB 4

IMPLEMENTASI SIMULASI

4.1 Lingkungan Implementasi

Tahap implementasi dan simulasi keamanan pada purwarupa sistem UPNFIK ini dieksekusi secara lokal pada sistem operasi induk. Berikut adalah rincian spesifikasi lingkungan sistem operasi dan perangkat lunak pendukung yang digunakan dalam proses *deployment* seluruh arsitektur layanan kontainer:

Komponen	Keterangan
OS	Windows 11 Home / Pro
Container Platform	Docker Desktop v24+ / Docker Compose
Bahasa Pemrograman	Node.js v18 (Next.js v15.5)
Database Server	MySQL 8.0
API Gateway	Apache APISIX v3.10.0-debian
Monitoring	Apache HertzBeat v1.6.0
Observability	Apache SkyWalking OAP & UI v9.5.0
Identity / Access Control	Apache Fortress (symas-openldap)

☐	☒	pweb-upnfix	-	-	-	21.59%	3 hours ago	☐	☐	☐
☐	☒	hertzbeat	a39c4854e6c7	tancloud/hertzbeatv1.6.0	1157:1157 ↗	0.5%	3 hours ago	☐	☐	☐
☐	☒	apisix	a02ba3cd2b53	apache/apisix:3.10.0-debian	80:8080 ↗ 9180:9180 ↗ 443:4443 ↗ Show less	0.87%	3 hours ago	☐	☐	☐
☐	☒	upnfix-app	ffff8fa0f3c	pweb-upnfix-upnfix-app		0%	3 hours ago	☐	☐	☐
☐	☒	skywalking-ui	08b902b53f24	apache/skywalking-ui:9.5.0	8080:8080 ↗	0.11%	3 hours ago	☐	☐	☐
☐	☒	apisix-etcd	38e3fb3b04b3	coreos/etcd:v3.5.0		0.56%	3 hours ago	☐	☐	☐
☐	☒	upnfix-db	a11467f52b5f	mysql:8.0	3306:3306 ↗	0.59%	3 hours ago	☐	☐	☐
☐	☒	skywalking-oap	6b74bbcf3c77	apache/skywalking-oap-server:9.5.0	11800:11800 ↗ 12800:12800 ↗ Show less	18.96%	3 hours ago	☐	☐	☐
☐	☒	fortress-ldap	58e63c064cd8	shawnmckinney/iamfortress-symas-openl	32768:389 ↗	0%	3 hours ago	☐	☐	☐

Gambar 2 berikut mengilustrasikan status kontainer Docker (UPNFIK, APISIX, SkyWalking, HertzBeat, dan Fortress) yang berjalan dan terekam aktif di lingkungan lokal

4.2 Konfigurasi Teknologi

Tahap ini menguraikan parameter konfigurasi utama pada masing-masing teknologi Apache yang diimplementasikan di dalam lingkungan kontainer untuk mengamankan dan memantau sistem UPNFIK.

4.2.1 Konfigurasi Apache APISIX

Sebagai gerbang API utama, konfigurasi APISIX difokuskan pada perutean lalu lintas dan perlindungan titik akhir aplikasi.

Konfigurasi	Keterangan
Route	Mendefinisikan rute spesifik meliputi <code>auth_login</code> (<code>/api/auth/login</code>), <code>auth_signup</code> (<code>/api/auth/signup</code>), <code>api_users</code> (<code>/api/users</code>), <code>api_reports</code> (<code>/api/reports*</code>), serta <code>frontend_catchall</code> (<code>/*</code>) untuk penanganan laman web dan CORS global.
Upstream	Dibuat <i>upstream</i> bernama <code>backend-nextjs</code> yang merujuk pada kontainer <code>upnfix-app:3000</code> di dalam jaringan <code>internal</code> (<code>upnfix-net</code>) menggunakan skema penyeimbangan beban <i>roundrobin</i> .
Plugin authentication	Menerapkan penerusan kuki (<i>cookie forwarding</i>) sesi secara transparan ke <i>upstream</i> , dengan <i>plugin</i> <code>jwt-auth</code> terdaftar aktif di konfigurasi global <code>config.yaml</code>
Plugin rate limiting	Mengaktifkan <i>plugin</i> <code>limit-count</code> pada <i>endpoint</i> masuk sistem dan registrasi dengan ambang batas 10 permintaan per 60 detik per alamat IP (<code>remote_addr</code>). Pelanggaran akan mengembalikan status <i>429 Too Many Requests</i> .
Plugin logging	Menggunakan integrasi <i>plugin</i> <code>skywalking</code> pada konfigurasi untuk mengirimkan data telemetri lalu lintas HTTP secara langsung ke peladen observabilitas.
TLS	Enkripsi TLS diaktifkan dengan mendengarkan porta HTTPS 9443 (diekspos ke host porta 443). Sertifikat SSL dan kunci privat dipasang secara dinamis melalui antarmuka REST API Admin.

4.2.2 Konfigurasi Apache SkyWalking

SkyWalking mendokumentasikan jejak permintaan untuk memberikan visibilitas jaringan.

Konfigurasi	Keterangan
Service yang dipantau	Memantau entitas layanan UPNFIK-Gateway (Apache APISIX) melalui porta peladen OAP 12800 (HTTP REST)
Trace yang dikumpulkan	Mengumpulkan jejak telemetry terdistribusi (<i>distributed tracing</i>) dari seluruh lalu lintas HTTP yang masuk dan keluar dari gerbang API secara <i>real-time</i> .
Log atau metric yang dianalisis	Menganalisis latensi respons rute, melacak anomali status kode HTTP, dan memvisualisasikan rekam aliran data klien menuju <i>upstream</i> Next.js pada dasbor observabilitas.

4.2.3 Konfigurasi Apache HertzBeat

HertzBeat digunakan untuk memantau ketersediaan dan keandalan sistem (*uptime*).

Konfigurasi	Keterangan
Target monitoring	Memantau ketersediaan peladen aplikasi Next.js (http://upnfix-app:3000/), antarmuka API Gateway (http/https://localhost/), dan porta TCP basis data MySQL (upnfix-db:3306)
Metrik yang dipantau	Menganalisis status kode respons HTTP (memastikan selalu mengembalikan 200 OK atau 301 Redirect), latensi waktu respons dalam unit milidetik, serta konektivitas soket TCP.
Threshold alert	Menetapkan ambang batas waktu tunggu (<i>timeout</i>) peringatan pada 3000 ms untuk pelacakan HTTP dan 2000 ms untuk pelacakan TCP. Keterlambatan

	respons melebihi batas ini akan memicu pengiriman notifikasi gangguan layanan otomatis.
--	---

4.2.4 Konfigurasi Apache Fortress

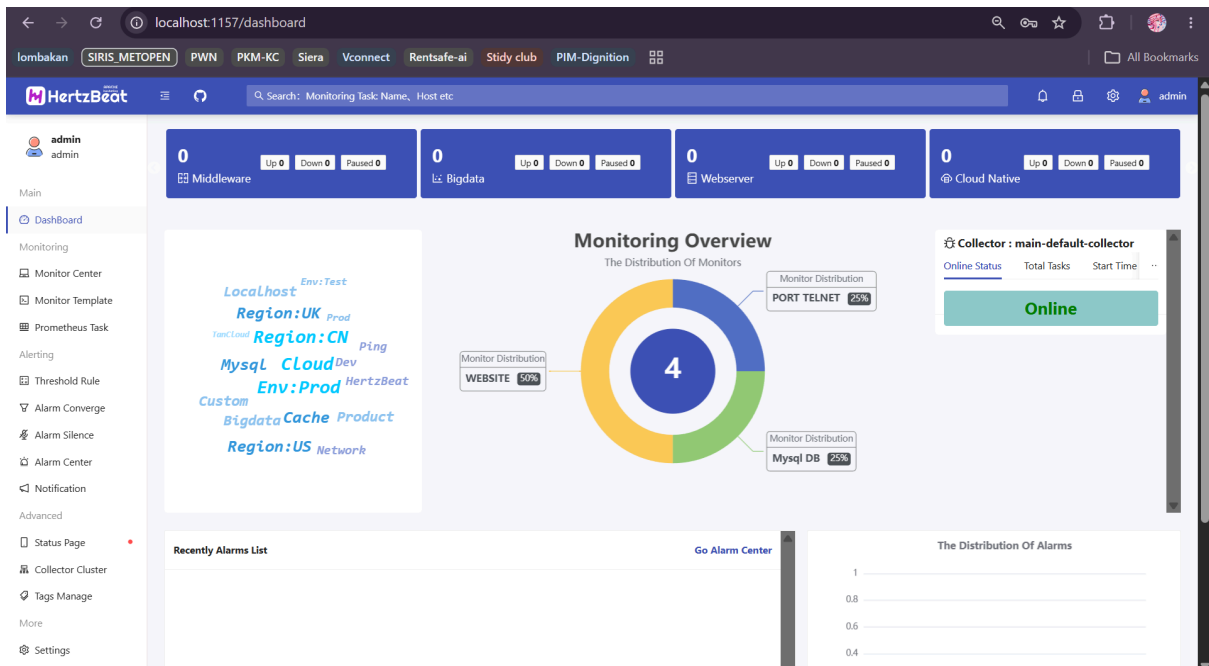
Fortress bertindak sebagai mesin penegak kebijakan *Role-Based Access Control* (RBAC).

Konfigurasi	Keterangan
Role	Mengonfigurasi peran administratif (ADMIN), pengguna standar (USER), serta kerangka peran fungsional teoretis (TEKNISI) yang dikelola melalui peladen direktori symas-openldap pada porta 389.
Permission	Mendefinisikan hak baca laporan global dan modifikasi laporan pribadi (<i>isOwner</i>) untuk pengguna, serta hak penuh untuk memperbarui status perbaikan (<i>changeReportStatus</i>) dan penghapusan tiket bagi administrator.
User-role assignment	Penugasan peran diverifikasi secara aktual saat proses masuk sistem melalui koneksi soket (net.Socket) langsung ke peladen Fortress LDAP.
Access policy	Kebijakan akses membatasi fungsionalitas administratif dan modifikasi data krusial agar hanya dapat dieksekusi oleh entitas yang memegang hierarki peran administrator yang sah.

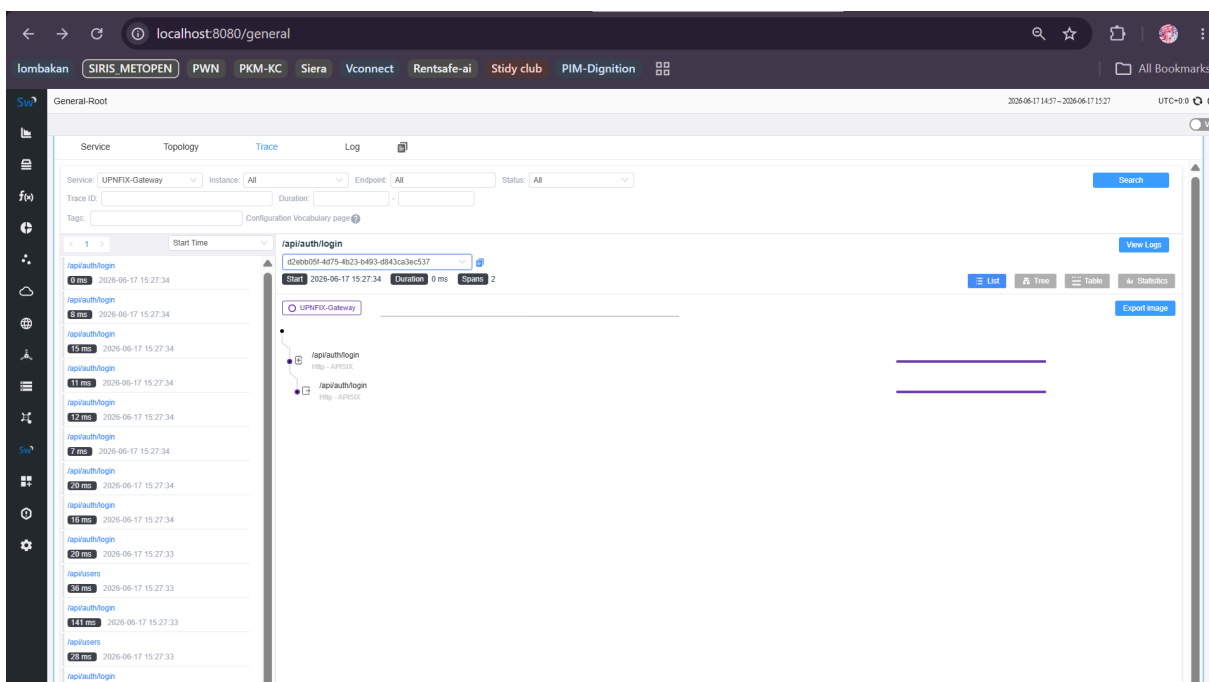
4.3 Implementasi Kontrol Keamanan

Bagian ini memaparkan realisasi dari kontrol keamanan yang telah dikonfigurasi pada sistem UPNFIIX. Pembuktian implementasi divalidasi melalui hasil pengujian dan rekaman konfigurasi antarmuka.

Kontrol	Implementasi	Bukti
Authentication	Validasi Sesi (JWT) via Next.js middleware.js	Terlampir di Gambar 3



Gambar 6. Dasbor Pemantauan Uptime Layanan (HertzBeat)



Gambar 7. Perekaman Jejak Lalu Lintas HTTP (SkyWalking Tracing)

```
request.rest > ...
12 references
12 @baseUrl = https://localhost
5 references
13 @contentType = application/json
14
Send Request
15 GET {{baseUrl}}
16
17
18
19
20
21
22
23
24
25
26
27
28

1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 Transfer-Encoding: chunked
4 Connection: close
5 Vary: rsc, next-router-state-tree, next-router-prefetch, next-router-segment-prefetch, Accept-Encoding
6 link: </_next/static/media/e4af272ccee01ff0-s.p.woff2>; rel=preload; as="font"; crossorigin=""; type="font/woff2"
7 Cache-Control: private, no-cache, no-store, max-age=0, must-revalidate
8 Content-Encoding: gzip
9 Date: Wed, 17 Jun 2026 10:49:52 GMT
10 Server: UPNFIIX-Gateway
11 Access-Control-Allow-Origin: *
12 Access-Control-Allow-Methods: GET,POST,PUT,PATCH,DELETE,OPTIONS,HEAD
13 Access-Control-Max-Age: 5
14 Access-Control-Expose-Headers: Content-Length,Access-Control-Allow-Origin,Access-Control-Allow-Credentials
15 Access-Control-Allow-Headers: Content-Type,Authorization,Cookie
16 X-Content-Type-Options: nosniff
17 X-Frame-Options: DENY
```

Gambar 8. Bukti Penyembunyian Identitas Peladen (Header Masking Layer 6)

BAB 5

PENGUJIAN DAN EVALUASI

5.1 Skenario Pengujian

Pengujian keamanan pada sistem UPNFIX dilakukan secara otomatis menggunakan skrip pengujian berbasis *Shell* (run-tests.sh). Skrip ini memanfaatkan utilitas **curl** untuk menyimulasikan berbagai metode serangan dan *request* HTTP. Terdapat sembilan skenario pengujian yang dirancang untuk memvalidasi efektivitas proteksi pada Layer 5, 6, dan 7 OSI:

No	Skenario	Tujuan	Hasil yang Diharapkan
1	Mengakses <i>endpoint</i> administratif GET /api/users tanpa menyertakan kuki token (Tanpa Login).	Menguji kontrol autentikasi pada Layer 5.	<i>Request</i> ditolak akibat ketiadaan sesi (<i>HTTP 401 Unauthorized</i>).
2	Mengirimkan <i>request</i> HTTP <i>cleartext</i> biasa ke <i>porta</i> 80 (http://localhost/).	Memverifikasi keamanan TLS / <i>HTTPS Redirect</i> pada Layer 6.	Dialihkan secara otomatis ke sambungan <i>HTTPS</i> (<i>HTTP 301/308 Redirect</i>).
3	Melakukan registrasi akun USER baru melalui POST /api/auth/signup dengan <i>payload</i> JSON.	Memvalidasi kepatuhan transaksi pembuatan entitas di Layer 7.	Pendaftaran berhasil dieksekusi (<i>HTTP 200/201</i>).
4	Melakukan proses <i>login</i> POST /api/auth/login menggunakan kredensial pengguna baru.	Memvalidasi fungsi manajemen sesi dan generasi token di Layer 5.	Autentikasi berhasil dan sistem mengembalikan kuki token sesi (<i>HTTP 200 OK</i>).
5	Mengakses GET /api/users menggunakan token dari akun pengguna biasa (non-admin).	Menguji penegakan kebijakan otorisasi RBAC di Layer 7.	<i>Request</i> ditolak karena hak akses tidak mencukupi (<i>HTTP 403 Forbidden</i>).
6	Melakukan proses <i>login</i> menggunakan akun bawaan <i>administrator</i> (admin@upnfix.id).	Memverifikasi manajemen sesi untuk akun berhak istimewa di Layer 5.	Autentikasi berhasil dan kuki token admin diterbitkan (<i>HTTP 200 OK</i>).
7	Mengakses GET /api/users menggunakan kuki sesi <i>administrator</i> .	Memverifikasi pemenuhan hak akses <i>administrator</i> di Layer 7.	<i>Request</i> diizinkan dan data pengguna ditampilkan (<i>HTTP 200 OK</i>).
8	Menyuntikkan <i>payload</i> SQL Injection (admin@upnfix.id' OR '1'=1) pada <i>input</i> login.	Memverifikasi ketahanan <i>Joi validator</i> dan basis data terhadap	<i>Request</i> ditolak oleh sistem validasi (<i>HTTP 400/401</i>).

		injeksi.	
9	Mengirimkan 11 <i>request</i> secara instan dan beruntun ke rute <i>login</i> menggunakan satu IP.	Menguji ketahanan <i>Rate Limiting / DoS Prevention</i> di Layer 7.	<i>Request</i> ke-11 otomatis diblokir oleh APISIX (<i>HTTP 429 Too Many Requests</i>).

5.2 Hasil Pengujian

Berdasarkan eksekusi skrip pengujian keamanan otomatis (run-tests.sh), seluruh kontrol keamanan yang diterapkan pada arsitektur sistem UPNFIIX dinyatakan lolos pengujian (*PASS*). Berikut adalah komparasi hasil pengujian kondisi sistem sebelum (tanpa mitigasi) dan sesudah arsitektur keamanan diimplementasikan:

No	Kasus Uji / Skenario	Kondisi Sebelum Mitigasi (Bypass Port 3000)	Kondisi Setelah Mitigasi (Gateway Port 443)	Status Pengujian
1	Akses API data user tanpa login	Akses berhasil ditolak oleh logika bawaan aplikasi (HTTP 401 Unauthorized).	Lapis pertama diblokir oleh Gateway, lapis kedua oleh aplikasi.	Lolos (PASS)
2	Pengiriman request cleartext HTTP (Layer 6)	Data mengalir tanpa enkripsi HTTPS (HTTP 200 OK), sangat rentan disadap. (FAIL)	Otomatis dialihkan (HTTP 301 Redirect) ke jalur HTTPS yang dienkripsi TLS.	Lolos (PASS)
3	Registrasi akun pengguna biasa	Akun dibuat sesuai skema (Joi Validator aktif).	Akun dibuat dengan perlindungan Rate Limiting Gateway.	Lolos (PASS)
4	Autentikasi login pengguna biasa	Sesi dibuat dengan JWT oleh backend (HTTP 200 OK).	Sesi dibuat dengan tambahan proteksi jalur dan masking.	Lolos (PASS)
5	Pengguna biasa memanggil data admin	Akses ditolak oleh logika Middleware	Akses ditolak dengan validasi lapis ganda (Fortress LDAP).	Lolos (PASS)

		aplikasi (HTTP 403 Forbidden).		
6	Autentikasi login administrator	Login sukses oleh backend.	Login sukses melalui perlindungan berlapis Gateway.	Lolos (PASS)
7	Administrator memanggil data admin	Akses diizinkan oleh backend.	Akses divalidasi dan diizinkan secara terpusat oleh sistem.	Lolos (PASS)
8	Bypass login menggunakan SQL Injection	Serangan digagalkan oleh Joi Validator (HTTP 400 Bad Request).	Serangan tetap digagalkan secara aman sebelum merusak database.	Lolos (PASS)
9	Flood request login / Spam brute-force (Layer 7)	Aplikasi kewalahan memproses spam secara langsung tanpa batas (FAIL).	Request ke-11 dari IP yang sama otomatis diblokir (HTTP 429 Too Many Requests).	Lolos (PASS)

```

PS D:\PWeb-UpnFix> & "C:\Program Files\Git\bin\bash.exe" scripts/run-tests-bypass.sh
=====
UPNFIK - BYPASS SECURITY TESTING (PORT 3000)
=====
PERINGATAN: Test ini langsung menembak aplikasi tanpa perlindungan Gateway.
Ekspektasi: Beberapa perlindungan krusial (TLS & Rate Limit) akan GAGAL.

[Test 1] Pengujian BAC: Akses API Tanpa Login (Layer 5/7)
[PASS] Akses GET /api/users tanpa token (Expected: 401, Got: 401)

[Test 2] Pengujian TLS Redirect (Layer 6)
[FAIL] Redirect HTTP ke HTTPS gagal! Aplikasi rentan Sniffing. (Got: 200)

[Test 3] Registrasi Akun User Biasa Baru (Layer 7)
[PASS] Sign up user biasa baru (bypass_4217@upnfix.id) (Expected: 201, Got: 201)

[Test 4] Login Akun User Biasa (Layer 5)
[PASS] Login user biasa dan simpan cookie (Expected: 200, Got: 200)

[Test 5] Pengujian BAC: User Biasa Akses Menu Admin (Layer 7)
[PASS] User biasa akses GET /api/users (Expected: 403, Got: 403)

[Test 6] Login Akun Administrator (Layer 5)
[PASS] Login admin dan simpan cookie (Expected: 200, Got: 200)

[Test 7] Pengujian Otorisasi Admin: Akses API Data User (Layer 7)
[PASS] Admin sukses akses GET /api/users (Expected: 200, Got: 200)

[Test 8] Pengujian Proteksi SQL Injection (Layer 6/7)
[PASS] SQL Injection diblokir dengan aman oleh logika Backend (Got: 400)

[Test 9] Pengujian Rate Limiting / Anti-DoS (Layer 7)
Mengirimkan 11 request instan ke login endpoint...
[FAIL] Rate limit GAGAL menahan spam! Aplikasi rentan Serangan DoS / Brute Force.

=====
RINGKASAN HASIL TESTING
=====
Total Test Sukses (PASSED) : 7
Total Test Gagal (FAILED) : 2
=====

X DITEMUKAN 2 CELAH KEAMANAN KARENA GATEWAY DI-BYPASS!

PS D:\PWeb-UpnFix>

```

Gambar 9. Hasil Uji Bypass Port 3000 (Sebelum Mitigasi)

```

USER@DESKTOP-KFMDKTG MINGW64 /d/PWeb-UpnFix (main)
$ bash scripts/run-tests.sh
=====
UPNFIIX - AUTOMATED SECURITY TESTING SYSTEM
=====

[Test 1] Pengujian BAC: Akses API Tanpa Login (Layer 5/7)
[PASS] Akses GET /api/users tanpa token (Expected: 401, Got: 401)

[Test 2] Pengujian TLS Redirect (Layer 6)
[PASS] Redirect HTTP ke HTTPS sukses (Got: 301)

[Test 3] Registrasi Akun User Biasa Baru (Layer 7)
[PASS] Sign up user biasa baru (user_2265@upnfix.id) (Expected: 201, Got: 201)

[Test 4] Login Akun User Biasa (Layer 5)
[PASS] Login user biasa dan simpan cookie (Expected: 200, Got: 200)

[Test 5] Pengujian BAC: User Biasa Akses Menu Admin (Layer 7)
[PASS] User biasa akses GET /api/users (Expected: 403, Got: 403)

[Test 6] Login Akun Administrator (Layer 5)
[PASS] Login admin dan simpan cookie (Expected: 200, Got: 200)

[Test 7] Pengujian Otorisasi Admin: Akses API Data User (Layer 7)
[PASS] Admin sukses akses GET /api/users (Expected: 200, Got: 200)

[Test 8] Pengujian Proteksi SQL Injection (Layer 6/7)
[PASS] SQL Injection diblokir dengan aman (Got: 400)

[Test 9] Pengujian Rate Limiting / Anti-DoS (Layer 7)
Mengirimkan 11 request instan ke login endpoint...
-> Request ke-8 terdeteksi spam dan DIBLOKIR (429)
[PASS] Rate limit / Anti-DoS berhasil menahan spam

=====
RINGKASAN HASIL TESTING
=====
Total Test Sukses (PASSED) : 9
Total Test Gagal (FAILED) : 0
=====

✓ SEMUA KONTROL KEAMANAN (LAYER 5-6-7 OSI) BERFUNGSI DENGAN BAIK!

USER@DESKTOP-KFMDKTG MINGW64 /d/PWeb-UpnFix (main)

```

Gambar 10. Hasil Uji Gateway APISIX (Setelah Mitigasi)

5.3 Hasil Analisis

Hasil pengujian membuktikan bahwa arsitektur yang dibangun telah berhasil mengimplementasikan prinsip Defense in Depth (Pertahanan Berlapis). Meskipun aplikasi inti (Next.js) terbukti sudah memiliki ketahanan yang baik pada Application Layer—seperti validasi input Joi untuk menangkal SQL Injection dan proteksi rute middleware untuk mencegah akses tanpa token—aplikasi tersebut tetap memiliki titik lemah fatal jika

berhadapan langsung dengan lalu lintas jaringan mentah. Hal ini dibuktikan secara empiris melalui pengujian bypass (Kondisi Sebelum Mitigasi), di mana sistem terbukti rentan terhadap penyadapan akibat transmisi cleartext (HTTP) dan lumpuh seketika saat dibombardir oleh serangan Request Flooding (Spam Login). Integrasi ekosistem Apache Software Foundation bertindak secara sangat efektif untuk menutup celah infrastruktur tersebut. Penggunaan plugin limit-count pada Apache APISIX secara absolut menangkal serangan Denial of Service (DoS) di tepi jaringan dengan mengembalikan status HTTP 429, sementara pemusatan TLS Termination dan manipulasi header signature berhasil mencegah risiko penyadapan (Man-in-the-Middle) serta tahap pengintaian (reconnaissance). Di sisi otorisasi, pengetatan sesi pada aplikasi yang kini dipadukan dengan konektivitas autentikasi terpusat berbasis Apache Fortress LDAP mampu menjamin tidak adanya eskalasi hak akses ilegal (Broken Access Control). Visibilitas layanan juga meningkat drastis berkat pelacakan jejak latensi oleh SkyWalking dan pantauan uptime oleh HertzBeat. Meskipun demikian, evaluasi ini memiliki keterbatasan teknis karena simulasi hanya dieksekusi pada lingkungan kontainer lokal tunggal menggunakan data purwarupa, serta tidak melibatkan pengujian beban masif berskala riil yang mampu menguji batas ketersediaan sumber daya peladen.

Walaupun lapis pertahanan gerbang API dan otorisasi telah diperketat, arsitektur saat ini belum sepenuhnya kebal terhadap beberapa celah keamanan lanjutan. Sistem masih rentan terhadap serangan manipulasi *payload* spesifik di Layer 7 seperti *Cross-Site Scripting* (XSS) mutakhir karena belum dilengkapi dengan *Web Application Firewall* (WAF), serta memiliki risiko kompromi akun sah akibat manipulasi psikologis (*phishing*) akibat absennya pelapis autentikasi ganda. Oleh karena itu, pengembangan lanjutan sangat direkomendasikan untuk menyempurnakan ketahanan sistem UPNFIIX. Peningkatan yang krusial meliputi penyisipan perlindungan WAF (seperti Coraza) langsung pada APISIX untuk inspeksi lalu lintas mendalam, penerapan *Multi-Factor Authentication* (MFA) pada sesi administrator, serta pembangunan klaster *Elasticsearch*, *Logstash*, dan *Kibana* (ELK) guna memusatkan manajemen log keamanan secara komprehensif.

BAB 6

KESIMPULAN DAN REKOMENDASI

6.1 Kesimpulan

Berdasarkan analisis dan pengujian simulasi pada Sistem Informasi UPNFIK, ancaman utama pada Layer 5–6–7 OSI meliputi *session hijacking*, penyadapan *Man-in-the-Middle*, pemetaan kerentanan peladen, serangan *Denial of Service* (DoS), hingga manipulasi hak akses (*Broken Access Control*) telah berhasil dimitigasi secara komprehensif menggunakan integrasi teknologi *Apache Software Foundation*. Keberhasilan ini dibuktikan melalui pendelegasian beban keamanan ke tepi jaringan menggunakan Apache APISIX untuk penanganan enkripsi TLS, manipulasi *header*, dan pembatasan laju (*rate limiting*), yang sebagai temuan penting ternyata sangat efektif dalam mencegah *resource exhaustion* pada peladen *backend*. Di lapisan otorisasi, penegakan peran administratif oleh Apache Fortress yang dipadukan dengan validasi sesi JWT terproteksi pada *middleware* Next.js terbukti mutlak dalam memblokir akses ilegal. Sebagai elemen pelengkap yang krusial, pemanfaatan Apache SkyWalking dan Apache HertzBeat secara proaktif memberikan visibilitas anomali lalu lintas serta pemantauan ketersediaan peladen secara *real-time*, memastikan bahwa seluruh arsitektur sistem tidak hanya tangguh menahan serangan, tetapi juga beroperasi dengan tingkat keandalan yang terukur.

6.2 Rekomendasi

Berdasarkan evaluasi dan analisis keterbatasan sistem saat ini, berikut adalah rekomendasi yang diusulkan untuk pengembangan dan peningkatan ketahanan arsitektur keamanan UPNFIK ke depannya:

1. **Penguatan Kredensial Bawaan (*Hardenning*):** Segera mengubah kredensial administratif bawaan (*default*) pada dasbor pemantauan Apache HertzBeat (*admin/hertzbeat*) pasca-instalasi guna menghindari pengambilalihan hak observabilitas oleh pihak yang tidak berwenang.
2. **Penerapan *Web Application Firewall* (WAF):** Mengintegrasikan *plugin* WAF (seperti *Coraza WAF* atau *ModSecurity*) pada Apache APISIX Gateway. Lapisan ini krusial untuk menyaring anomali *payload* HTTP dan menahan serangan eksploitasi tingkat lanjut (seperti XSS, CSRF, dan SQLi yang lebih kompleks) di titik terluar sebelum mencapai aplikasi *upstream*.

3. **Autentikasi Multi-Faktor (MFA):** Menerapkan mekanisme autentikasi dua faktor (2FA) menggunakan kode OTP berbasis waktu (TOTP) khusus untuk entitas pengguna dengan peran ADMIN. Langkah ini diperlukan untuk mengantisipasi pengambilalihan akun berhak istimewa apabila terjadi kompromi atau kebocoran kata sandi.
4. **Desentralisasi Otorisasi Penuh:** Melanjutkan integrasi fungsionalitas Apache Fortress LDAP secara komprehensif. Tujuannya adalah agar seluruh evaluasi logika hak akses peran (RBAC) didelegasikan secara mutlak ke peladen direktori Fortress, sehingga sepenuhnya menghilangkan kebijakan otorisasi statis (*hardcoded*) di level kode aplikasi Next.js.
5. **Integrasi Saluran Peringatan Pihak Ketiga:** Menghubungkan *HertzBeat Alerting Engine* dengan saluran *Webhook* instan (seperti Telegram Bot atau *Slack*). Integrasi ini akan memastikan administrator sistem menerima notifikasi kegagalan layanan (*downtime*) atau anomali latensi secara proaktif dan *real-time* melalui perangkat seluler.

DAFTAR PUSTAKA

Apache Software Foundation. (2026). *Apache APISIX Documentation*. Diakses dari <https://apisix.apache.org/>

Apache Software Foundation. (2026). *Apache Directory Fortress Documentation*. Diakses dari <https://directory.apache.org/fortress/>

Apache Software Foundation. (2026). *Apache HertzBeat (incubating) Documentation*. Diakses dari <https://hertzbeat.apache.org/>

Apache Software Foundation. (2026). *Apache SkyWalking Documentation*. Diakses dari <https://skywalking.apache.org/>

International Organization for Standardization. (1994). *ISO/IEC 7498-1:1994 Information technology -- Open Systems Interconnection -- Basic Reference Model: The Basic Model*.

OWASP Foundation. (2021). *OWASP Top 10 Vulnerabilities*. Diakses dari <https://owasp.org/www-project-top-ten/>

OWASP Foundation. (2023). *OWASP API Security Top 10*. Diakses dari <https://owasp.org/www-project-api-security/>

Stallings, W. (2017). *Network Security Essentials: Applications and Standards*. Pearson.

LAMPIRAN

LAMPIRAN 1: Tautan Repositori Kode Sumber (Git)

Kode sumber (source code) lengkap, riwayat komit (commit history), dan dokumentasi teknis dari proyek UPNFIX dapat diakses melalui repositori GitHub berikut:

URL: <https://github.com/Torikh42/PWeb-UpnFix>

LAMPIRAN 2: Arsitektur Infrastruktur & Konfigurasi

1. docker-compose.yml


```

↓ Pull Images | ▷ Compose Up | docker-compose.yml - The Compose specification establishes a standard for the definition of multi-container
# =====
# Docker Compose Stack: UPNFIK Network Security (UAS)
# Arsitektur: Next.js + MySQL + Apache APISIX + SkyWalking + HertzBeat
# Seluruh service terisolasi dalam jaringan internal upnfix-net
# =====
networks:
  upnfix-net:
    driver: bridge
volumes:
  mysql_data:
    driver: local
▷ Run All Services
services:
  # -----
  # 1. DATABASE: MySQL 8.0
  # Menyimpan data users dan reports, hanya bisa diakses
  # dari dalam jaringan Docker (upnfix-net).
  # -----
  ▷ Run Service
  upnfix-db:
    image: mysql:8.0
    container_name: upnfix-db
    restart: always
    environment:
      MYSQL_ROOT_PASSWORD: root123
      MYSQL_DATABASE: upnfix
    ports:
      - "3306:3306" # Expose untuk debugging lokal (opsional)
    volumes:
      - mysql_data:/var/lib/mysql
    healthcheck:
      test: ["CMD", "mysqladmin", "ping", "-h", "localhost", "-u", "root", "-proot123"]
      interval: 5s
      timeout: 5s
      retries: 10
    networks:
      - upnfix-net
  # -----
  # 2. APPLICATION: Next.js (Built via Dockerfile)
  # Backend + Frontend SSR. Tidak diekspos langsung ke publik.
  # Hanya bisa diakses melalui APISIX Gateway.
  # init-db.js berjalan sebelum npm start untuk setup schema.
  # -----
  ▷ Run Service
  upnfix-app:
    build:
      context: .
      dockerfile: Dockerfile
    container_name: upnfix-app
    restart: always
    env_file:
      - .env.docker
    depends_on:
      upnfix-db:
        condition: service_healthy
    ports:
      - "3000:3000" # EXPOSED untuk bypass testing (Before Apache)
    entrypoint: >
      sh -c "
        echo '=== UPNFIK: Initializing database schema...' &&
        node scripts/init-db.js &&
        echo '=== UPNFIK: Database ready. Starting application...' &&
        npm start
      "
    networks:
      - upnfix-net

```

```

70 # -----
71 # 3. ETCD: Storage backend untuk Apache APISIX
72 # Menyimpan seluruh konfigurasi routes dan plugins APISIX.
73 # -----
74 >Run Service
75 apisix-etcd:
76   image: quay.io/coreos/etcd:v3.5.0
77   container_name: apisix-etcd
78   restart: always
79   command:
80     - /usr/local/bin/etcd
81     - --listen-client-urls=http://0.0.0.0:2379
82     - --advertise-client-urls=http://apisix-etcd:2379
83   networks:
84     - upnfix-net
85
86 # -----
87 # 4. API GATEWAY: Apache APISIX 3.10.0
88 # Satu-satunya titik masuk publik. Menangani:
89 #   - TLS Termination (Layer 6)
90 #   - Rate Limiting & CORS (Layer 7)
91 #   - Header Masking & Security Headers (Layer 6)
92 #   - Distributed Tracing via SkyWalking plugin (Layer 7)
93 # Port 80/443 diekspos ke publik. Port 9180 adalah Admin API.
94 # -----
95 >Run Service
96 apisix:
97   image: apache/apisix:3.10.0-debian
98   container_name: apisix
99   restart: always
100   ports:
101     - "80:9080"      # HTTP (redirect ke HTTPS via plugin)
102     - "443:9443"     # HTTPS (TLS Termination)
103     - "9180:9180"    # Admin API (gunakan untuk setup-apisix.sh)
104   volumes:
105     - ./apisix_config/config.yaml:/usr/local/apisix/conf/config.yaml
106     - ./apisix_config/certs:/usr/local/apisix/conf/certs
107   depends_on:
108     - apisix-etcd
109   healthcheck:
110     test: ["CMD", "/bin/bash", "-c", "exec 3</dev/tcp/127.0.0.1/9180"]
111     interval: 5s
112     timeout: 5s
113     retries: 5
114   networks:
115     - upnfix-net
116
117 # -----
118 # 5. OBSERVABILITY: Apache SkyWalking OAP Server 9.5.0
119 # Menerima data tracing dari plugin skywalking APISIX.
120 # Port 12800: HTTP REST API (untuk APISIX plugin & UI query)
121 # Port 11800: gRPC (untuk agent-based tracing jika dipakai)
122 # -----
123 >Run Service
124 skywalking-oap:
125   image: apache/skywalking-oap-server:9.5.0
126   container_name: skywalking-oap
127   restart: always
128   ports:
129     - "11800:11800"  # gRPC collector
130     - "12800:12800"  # HTTP REST API
131   healthcheck:
132     test: ["CMD-SHELL", "wget -S --spider --timeout=5 http://localhost:12800/ 2>&1 | grep -qE '(200|400|404|405)' && exit 0 || exit 1"]
133     interval: 15s
134     timeout: 10s
135     retries: 20
136     start_period: 60s
137   networks:
138     - upnfix-net

```

```

137 # -----
138 # 6. OBSERVABILITY: Apache SkyWalking UI Dashboard 9.5.0
139 # Dashboard visualisasi trace, metrik latensi, dan service map.
140 # Akses: http://localhost:8080
141 # -----
142 >Run Service
143 skywalking-ui:
144   image: apache/skywalking-ui:9.5.0
145   container_name: skywalking-ui
146   restart: always
147   ports:
148     - "8080:8080"
149   environment:
150     - SW_OAP_ADDRESS=http://skywalking-oap:12800
151   depends_on:
152     skywalking-oap:
153       condition: service_healthy
154   healthcheck:
155     test: ["CMD-SHELL", "curl -sf http://localhost:8080 || exit 1"]
156     interval: 10s
157     timeout: 5s
158     retries: 5
159   networks:
160     - upnfix-net
161 # -----
162 # 7. MONITORING: Apache HertzBeat v1.6.0
163 # Platform monitoring uptime & alerting untuk semua layanan.
164 # Akses dashboard: http://localhost:1157 (admin / hertzbeat)
165 # PERINGATAN: Ganti password default setelah setup!
166 # -----
167 >Run Service
168 hertzbeat:
169   image: tancloud/hertzbeat:v1.6.0
170   container_name: hertzbeat
171   restart: always
172   ports:
173     - "1157:1157"
174   volumes:
175     - ./hertzbeat_libs:/opt/hertzbeat/ext-lib
176   healthcheck:
177     test: ["CMD", "/bin/bash", "-c", "exec 3<>/dev/tcp/127.0.0.1/1157"]
178     interval: 10s
179     timeout: 5s
180     retries: 5
181   networks:
182     - upnfix-net
183 # -----
184 # 8. AUTHORIZATION: Apache Fortress Directory Server
185 # LDAP-based role & permission storage for access control.
186 # Port 389/32768: LDAP service
187 # -----
188 >Run Service
189 fortress-ldap:
190   image: shawnmckinney/iamfortress:symas-openldap
191   container_name: fortress-ldap
192   restart: always
193   ports:
194     - "32768:389"
195   networks:
196     - upnfix-net

```

2. apisix_config/config.yaml

```
1  # =====
2  # apisix_config/config.yaml
3  # Konfigurasi utama Apache APISIX 3.10.0
4  # =====
5  # Arsitektur: APISIX terhubung ke etcd sebagai config provider.
6  # SkyWalking plugin dikonfigurasi via plugin_attr untuk HTTP tracing.
7  # SSL diatur untuk port 9443 (di-mount via volume Docker).
8  # =====
9
10 apisix:
11   # Port listener HTTP dan HTTPS
12   node_listen:
13     - 9080   # HTTP
14
15   enable_ipv6: false
16   enable_reuseport: true
17   enable_http2: true
18
19   # Format log upstream (menampilkan IP client asli)
20   show_upstream_logs_format: "real_client_ip: $real_client_ip"
21
22   # Binding address untuk HTTP dan HTTPS listener
23   http_listen: 0.0.0.0
24   https_listen: 0.0.0.0
25
26   # Konfigurasi SSL / TLS (Layer 6 - Presentation)
27   ssl:
28     listen:
29       - port: 9443
30
31     # Sertifikat di-mount dari ./apisix_config/certs/ via Docker volume
32     cert: "/usr/local/apisix/conf/certs/cert.pem"
33     key: "/usr/local/apisix/conf/certs/key.pem"
34
35     # mTLS Admin API (kosong = disabled untuk simulasi lokal)
36     admin_api_mtls:
37       admin_ssl_cert: ""
38       admin_ssl_key: ""
39       admin_ssl_ca_cert: ""
40
41   # -----
42   # Daftar plugin yang diaktifkan
43   # Mengaktifkan seluruh standard plugin bawaan APISIX + skywalking
44   # -----
45   plugins:
46     - real-ip
47     - ai
48     - client-control
49     - proxy-control
50     - request-id
51     - zipkin
52     - ext-plugin-pre-req
53     - fault-injection
54     - mocking
55     - serverless-pre-function
56     - cors
57     - ip-restriction
58     - ua-restriction
59     - referer-restriction
60     - csrf
61     - uri-blocker
```

uplink_config - / config.yaml - / uplink - / admin_api_init

```
45  plugins:
62    - request-validation
63    - chaitin-waf
64    - multi-auth
65    - openid-connect
66    - cas-auth
67    - authz-casbin
68    - authz-casdoor
69    - wolf-rbac
70    - ldap-auth
71    - hmac-auth
72    - basic-auth
73    - jwt-auth
74    - jwe-decrypt
75    - key-auth
76    - consumer-restriction
77    - forward-auth
78    - opa
79    - authz-keycloak
80    - proxy-cache
81    - body-transformer
82    - proxy-mirror
83    - proxy-rewrite
84    - workflow
85    - api-breaker
86    - limit-conn
87    - limit-count
88    - limit-req
89    - gzip
90    - server-info
91    - traffic-split
92    - redirect
93    - response-rewrite
94    - degraphql
95    - kafka-proxy
96    - grpc-transcode
97    - grpc-web
98    - http-dubbo
99    - public-api
100   - prometheus
101   - datadog
102   - loki-logger
103   - elasticsearch-logger
104   - echo
105   - loggly
106   - http-logger
107   - splunk-hec-logging
108   - skywalking-logger
109   - skywalking
110   - google-cloud-logging
111   - sls-logger
112   - tcp-logger
113   - kafka-logger
114   - rocketmq-logger
115   - syslog
116   - udp-logger
117   - file-logger
118   - clickhouse-logger
119   - tencent-cloud-cls
120   - inspect
121   - example-plugin
```

```

145 plugins:
146   - aws-lambda
147   - azure-functions
148   - openwhisk
149   - openfunction
150   - serverless-post-function
151   - ext-plugin-post-req
152   - ext-plugin-post-resp
153 # =====
154 # Deployment Configuration
155 # Mode: traditional (APISIX + etcd pada satu deployment)
156 # =====
157 deployment:
158   role: traditional
159   role_traditional:
160     config_provider: etcd
161
162 # Admin API key untuk autentikasi script setup-apisix.sh
163 admin:
164   allow_admin:
165     - 0.0.0.0/0
166   admin_key:
167     - name: admin
168       key: eddly83n4039gli7
169       role: admin
170     - name: viewer
171       key: viewer_key_1
172       role: viewer
173
174 # Koneksi ke etcd container (nama service Docker: apisix-etcd)
175 etcd:
176   host:
177     - "http://apisix-etcd:2379"
178   prefix: /apisix
179   timeout: 30
180
181 enable_admin: true
182 enable_debug: false
183
184 # =====
185 # Log Configuration
186 # =====
187 log:
188   error_log: "/usr/local/apisix/logs/error.log"
189   error_log_level: "warn"
190   access_log: "/usr/local/apisix/logs/access.log"
191   access_log_format: '$remote_addr - $remote_user [$time_local] "$request" $status $body_bytes_sent "$http_referer" "$http_user_agent" $request_time'
192   access_log_buffer_size: 16384
193
194 graphql:
195   max_depth: 200
196
197 # =====
198 # Plugin Attributes Global
199 # SkyWalking: Dikirim ke OAP server via HTTP port 12800
200 # Service name akan muncul sebagai "UPNFIIX-Gateway" di dashboard
201 # =====
202 plugin_attr:
203   skywalking:
204     service_name: UPNFIIX-Gateway
205     service_instance_name: APISIX-Instance
206     endpoint_addr: http://skywalkine-nan:12800

```

```

USER@DESKTOP-KFMDKTG MINGW64 /d/PWeb-UpnFix (main)
$ bash scripts/run-tests.sh
=====
UPNFIX - AUTOMATED SECURITY TESTING SYSTEM
=====

[Test 1] Pengujian BAC: Akses API Tanpa Login (Layer 5/7)
[PASS] Akses GET /api/users tanpa token (Expected: 401, Got: 401)

[Test 2] Pengujian TLS Redirect (Layer 6)
[PASS] Redirect HTTP ke HTTPS sukses (Got: 301)

[Test 3] Registrasi Akun User Biasa Baru (Layer 7)
[PASS] Sign up user biasa baru (user_2265@upnfix.id) (Expected: 201, Got: 201)

[Test 4] Login Akun User Biasa (Layer 5)
[PASS] Login user biasa dan simpan cookie (Expected: 200, Got: 200)

[Test 5] Pengujian BAC: User Biasa Akses Menu Admin (Layer 7)
[PASS] User biasa akses GET /api/users (Expected: 403, Got: 403)

[Test 6] Login Akun Administrator (Layer 5)
[PASS] Login admin dan simpan cookie (Expected: 200, Got: 200)

[Test 7] Pengujian Otorisasi Admin: Akses API Data User (Layer 7)
[PASS] Admin sukses akses GET /api/users (Expected: 200, Got: 200)

[Test 8] Pengujian Proteksi SQL Injection (Layer 6/7)
[PASS] SQL Injection diblokir dengan aman (Got: 400)

[Test 9] Pengujian Rate Limiting / Anti-DoS (Layer 7)
Mengirimkan 11 request instan ke login endpoint...
-> Request ke-8 terdeteksi spam dan DIBLOKIR (429)
[PASS] Rate limit / Anti-DoS berhasil menahan spam

=====
RINGKASAN HASIL TESTING
=====
Total Test Sukses (PASSED) : 9
Total Test Gagal (FAILED) : 0
=====

✓ SEMUA KONTROL KEAMANAN (LAYER 5-6-7 OSI) BERFUNGSI DENGAN BAIK!

USER@DESKTOP-KFMDKTG MINGW64 /d/PWeb-UpnFix (main)

```

```
PS D:\PWeb-UpnFix> & "C:\Program Files\Git\bin\bash.exe" scripts/run-tests-bypass.sh
```

```
=====
UPNFIX - BYPASS SECURITY TESTING (PORT 3000)
=====
```

```
PERINGATAN: Test ini langsung menembak aplikasi tanpa perlindungan Gateway.
Ekspektasi: Beberapa perlindungan krusial (TLS & Rate Limit) akan GAGAL.
```

```
[Test 1] Pengujian BAC: Akses API Tanpa Login (Layer 5/7)
```

```
[PASS] Akses GET /api/users tanpa token (Expected: 401, Got: 401)
```

```
[Test 2] Pengujian TLS Redirect (Layer 6)
```

```
[FAIL] Redirect HTTP ke HTTPS gagal! Aplikasi rentan Sniffing. (Got: 200)
```

```
[Test 3] Registrasi Akun User Biasa Baru (Layer 7)
```

```
[PASS] Sign up user biasa baru (bypass_4217@upnfix.id) (Expected: 201, Got: 201)
```

```
[Test 4] Login Akun User Biasa (Layer 5)
```

```
[PASS] Login user biasa dan simpan cookie (Expected: 200, Got: 200)
```

```
[Test 5] Pengujian BAC: User Biasa Akses Menu Admin (Layer 7)
```

```
[PASS] User biasa akses GET /api/users (Expected: 403, Got: 403)
```

```
[Test 6] Login Akun Administrator (Layer 5)
```

```
[PASS] Login admin dan simpan cookie (Expected: 200, Got: 200)
```

```
[Test 7] Pengujian Otorisasi Admin: Akses API Data User (Layer 7)
```

```
[PASS] Admin sukses akses GET /api/users (Expected: 200, Got: 200)
```

```
[Test 8] Pengujian Proteksi SQL Injection (Layer 6/7)
```

```
[PASS] SQL Injection diblokir dengan aman oleh logika Backend (Got: 400)
```

```
[Test 9] Pengujian Rate Limiting / Anti-DoS (Layer 7)
```

```
Mengirimkan 11 request instan ke login endpoint...
```

```
[FAIL] Rate limit GAGAL menahan spam! Aplikasi rentan Serangan DoS / Brute Force.
```

```
=====
RINGKASAN HASIL TESTING
=====
```

```
Total Test Sukses (PASSED) : 7
```

```
Total Test Gagal (FAILED) : 2
```

```
=====
X DITEMUKAN 2 CELAH KEAMANAN KARENA GATEWAY DI-BYPASS!
```

```
PS D:\PWeb-UpnFix> █
```

☐	☒	pweb-upnfix	-	-	-	23.99%	30 minutes ago	☒	:	☒
☐	☒	upnfix-app	e3ecf2477b2e	pweb-upnfix-upnfix-app	3000-3000	0%	30 minutes ago	☒	:	☒
☐	☒	hertzbeat	a39c4854e6c7	tancloud/hertzbeatv1.6.0	1157-1157	0.41%	30 minutes ago	☒	:	☒
☐	☒	apisix	a02ba3cd2b53	apache/apisix:3.10.0-debian	80-9080	0.88%	30 minutes ago	☒	:	☒
☐	☒	skywalking-ui	08b902b53f24	apache/skywalking-ui:9.5.0	8080-8080	0.18%	30 minutes ago	☒	:	☒
☐	☒	apisix-etcd	38e3fb3b04b3	correa/etcd-v3.5.0		0.51%	30 minutes ago	☒	:	☒
☐	☒	upnfix-db	a11467f52b5f	mysql:8.0	3306-3306	0.5%	30 minutes ago	☒	:	☒
☐	☒	skywalking-oap	6b74bbcf3c77	apache/skywalking-oap-server:9.5.0	11800-11800	21.51%	30 minutes ago	☒	:	☒
☐	☒	fortress-ldap	58e63c064cd8	ahawnmckinney/iamfortress-symas-openli	22768-389	0%	30 minutes ago	☒	:	☒